VENDOR RISK ASSESSMENT & THIRD-PARTY SECURITY STANDARD

Standard Ref: VRA-2026-02 | Owner: Enterprise Risk & CISO Office

Section 1: Supplier Tiering and Onboarding Gates

1.1 Every third-party SaaS vendor, managed service provider, or subprocessor must complete a security risk assessment before handling Company Data. Vendors are assigned Tier 1 (Critical), Tier 2 (Confidential), or Tier 3 (Public/Low Risk) based on data classification defined in company_compliance_policy.html.

1.2 Procurement contracts must prohibit vendor onboarding into production without CISO sign-off, except for Tier 3 trial tools capped at 14 days using synthetic non-production datasets governed under Clause 3.2.

Section 2: Cryptographic, Access, and Subprocessor Controls

2.1 Tier 1 and Tier 2 suppliers must enforce TLS 1.3 for all transit channels and AES-256 encryption at rest with tenant-isolated key wrapping. Shared static API secrets across multiple customer tenants are strictly prohibited.

2.2 Subprocessor Notification: Suppliers must maintain an up-to-date subprocessor registry and provide at least thirty (30) calendar days advance written notice before engaging any fourth-party AI inference host or cloud storage subprocessor. This aligns with Subprocessor obligations in Section 4.3 of master_services_agreement.pdf.

2.3 Independent Assurance: Tier 1 vendors must deliver an annual SOC 2 Type II or ISO/IEC 27001 surveillance audit report plus annual external penetration test summary with zero unmitigated Critical or High CVSS >= 7.5 findings older than 30 days.

Section 3: Continuous Monitoring, Exit, and Risk Exceptions

3.1 Continuous Monitoring: Security Operations subscribes to vendor trust centers and triggers out-of-cycle reassessment within five (5) business days following any publicly disclosed supplier breach, ownership acquisition, or critical CVE notice.

3.2 Exception & Provisional Onboarding Carve-Out: A business sponsor may request provisional 45-day onboarding while a SOC 2 bridge letter or penetration test remediation is pending, provided that (a) no Restricted PII or payment credentials enter the vendor environment, (b) compensating network egress firewall rules and SSO SCIM deprovisioning are verified active by Identity Engineering, and (c) both the Data Protection Officer and CISO co-sign a time-boxed Risk Acceptance Memo.
3.3 Contract Termination & Sanitization: Upon vendor offboarding, the supplier must return exported Company Data in open JSON/CSV formats within 30 days and issue a signed NIST SP 800-88 certificate of media sanitization within 45 days.